MODULE 18 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

Encryption and Key Management

Customer managed keys and rotation, where key material lives, certificates for TLS 1.3, and when a dedicated HSM is required.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 18 of 52

admin@sthithapragna.com

Encryption is easy to switch on. The architecture is in **who controls the key**, where it lives, and how it changes.

Three kinds of KMS key

KEY TYPE	YOU CONTROL	ROTATION
AWS owned	Nothing; not visible in your account	Set by AWS
AWS managed	Can see and audit use only	Yearly, cannot change
Customer managed	Key policy, grants, enable, disable, delete	Optional, 90 to 2560 days

ON THE EXAM

A requirement to control access, audit use, share cross-account or choose rotation means a customer managed key.

Automatic rotation

- **Period:** any value from 90 to 2560 days; default 365.
- **On-demand rotation** as well, for an immediate new version.
- **Same key ID and ARN.** Old versions kept, so old data still decrypts.
- **Supported:** symmetric keys with KMS-generated material, multi-Region included.
- **Not automatic:** asymmetric, HMAC, imported material, custom key stores.

> ON THE EXAM
>
> Rotation changes the key material, not the key. Nothing re-encrypts and no application changes.

Where does the key material live?

OPTION	MATERIAL IS IN	CHOOSE IT WHEN
Standard KMS	KMS HSMs, multi-tenant	Default; FIPS 140-3 Level 3 validated
Imported key material	KMS, generated by you	You must create or escrow the material
CloudHSM key store	Your dedicated CloudHSM cluster	Single-tenant HSM, with KMS integration
External key store	Your HSM outside AWS	Material must never be in AWS

ON THE EXAM

Every option keeps the KMS API, so S3, EBS and RDS encryption keep working unchanged.

CloudHSM directly, or through KMS?

KMS CUSTOM KEY STORE

Dedicated HSM, AWS integration

- Keys in your CloudHSM cluster
- S3, EBS, RDS use them via KMS
- KMS policies, grants, CloudTrail
- Symmetric encryption keys only

CLOUDHSM DIRECTLY

Your application calls the HSM

- PKCS#11, JCE, OpenSSL interfaces
- Any algorithm the HSM supports
- TLS offload, Oracle TDE, code signing
- No native AWS service integration

THE TIEBREAKER

Dedicated HSM plus native AWS service encryption: custom key store. Your own crypto operations: CloudHSM directly.

Multi-Region keys

- **Primary and replicas** share key ID and key material across Regions.
- **Encrypt in one Region, decrypt in another** with no cross-Region call.
- **Each replica has its own key policy**; rotation is synchronised.
- **Use for** client-side encryption with global tables, DR, cross-Region signing.
- **Not needed** when the service re-encrypts on replication, such as S3 CRR.

> ON THE EXAM
>
> Ciphertext moving between Regions, with decryption needed during a Regional outage: multi-Region keys.

Certificates for encryption in transit

NEED	SERVICE
Public TLS on ALB, CloudFront, API Gateway	ACM public certificate, free, auto-renewed
Public certificate installed on your own server	ACM exportable public certificate
Internal names, client identity, mutual TLS	AWS Private CA
Very short-lived internal certificates	Private CA short-lived certificate mode

ON THE EXAM

ACM public certificates now default to 198 days, so renewal must be automatic, not a calendar reminder.

TLS 1.3 and mutual TLS

- **Security policies** on ALB, NLB and CloudFront select TLS 1.3 and allowed ciphers.
- **TLS 1.3 only** policies exist where older clients can be refused.
- **ALB mutual TLS:** verify mode checks client certificates against a trust store.
- **Passthrough mode** forwards the client certificate for the target to check.
- **End to end:** re-encrypt from load balancer to target where rules require.

ON THE EXAM

Load balancer validates client certificates from your private CA: ALB mutual TLS in verify mode.

Reading the scenario

WHEN THE QUESTION SAYS	IT IS TESTING
Rotate every 180 days, no app change	Customer managed key, custom rotation period
Single-tenant HSM, keep S3 and EBS encryption	KMS custom key store on CloudHSM
Key material must stay outside AWS	External key store
Decrypt in another Region during an outage	Multi-Region keys
Public certificate on an EC2 appliance	ACM exportable certificate
Clients prove identity with certificates	Private CA plus ALB mutual TLS

ON THE EXAM

FIPS 140-3 Level 3 alone does not require CloudHSM. Standard KMS is validated too. Single tenancy does.

> Meridian Freight encrypts customs documents in S3 with SSE-KMS using an AWS managed key. A new regulation requires the encryption key material to rotate every 180 days.
>
> The change must not require re-encrypting existing objects or changing the application.

What should the solutions architect do?

A Switch to a customer managed key with automatic rotation set to 180 days

B Keep the AWS managed key and set its rotation period to 180 days

C Create a new key every 180 days and re-encrypt all objects with S3 Batch Operations

D Import key material into a customer managed key and enable automatic rotation

◆ PAUSE AND DECIDE

What should the solutions architect do?

A Customer managed, 180 days

Custom periods are supported; old versions still decrypt existing objects.

B AWS managed, 180 days

AWS managed keys rotate yearly; the period cannot be changed.

C New key and re-encrypt

Meets the rule, but re-encrypts everything, which is ruled out.

D Imported material

Automatic rotation is not available for imported key material.

THE SIGNAL

A custom rotation period needs a customer managed key with KMS-generated material.

A banking regulator requires Meridian Freight's payments subsidiary to hold its encryption keys in single-tenant hardware security modules that only the company administers.

The subsidiary wants to keep using SSE-KMS for Amazon S3 and KMS encryption for Amazon EBS and Amazon RDS.

What should the solutions architect recommend?

A. Standard customer managed KMS keys, which use FIPS-validated HSMs

B. CloudHSM used directly, with client-side encryption in each application

C. An external key store pointing at an on-premises HSM

D. A KMS custom key store backed by a CloudHSM cluster the company administers

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A Standard KMS

Validated, but multi-tenant and administered by AWS.

B CloudHSM directly

Single-tenant, but loses SSE-KMS and native service encryption.

C External key store

Adds an on-premises dependency the requirement never asked for.

D CloudHSM key store

Dedicated HSMs the company controls, behind the KMS API services use.

THE SIGNAL

Single-tenant HSM and native service encryption together means a CloudHSM-backed custom key store.

> A European customer requires that Meridian Freight's encryption keys for its data never exist inside AWS, and that Meridian can make the data unreadable to AWS at any time by withdrawing access to the keys.
>
> Data must stay in S3 with SSE-KMS.

Which design meets the requirement?

A. A customer managed key with imported key material, deleted when access must end

B. A KMS external key store connected to Meridian's own HSM outside AWS

C. A KMS custom key store backed by CloudHSM

D. A customer managed key with a key policy that denies AWS service principals

◆ PAUSE AND DECIDE

Which design meets the requirement?

A Imported material

You can delete it, but a copy lives in KMS while in use.

B External key store

Material stays in Meridian's HSM; disconnecting stops all decryption.

C CloudHSM key store

Dedicated, but the HSMs are inside AWS.

D Restrictive key policy

S3 needs KMS to decrypt; denying it breaks SSE-KMS.

THE SIGNAL

Never inside AWS means an external key store. Every other option keeps material in AWS hardware.

> Meridian Freight's partner integration API sits behind an Application Load Balancer. Each partner system must authenticate with a client certificate before any request reaches the application.
>
> Certificates should be issued by Meridian and be short-lived, so a leaked certificate expires within days.

What should the solutions architect implement?

A. ACM public certificates issued to each partner

B. Self-signed certificates checked in the application code

C. AWS Private CA in short-lived certificate mode, with ALB mutual TLS in verify mode using a trust store

D. A Network Load Balancer with TLS passthrough and no validation

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A ACM public certificates

Server certificates for your domains, not client identities Meridian issues.

B Self-signed, checked in code

Requests reach the application before being rejected.

C Private CA plus ALB mTLS

Meridian-issued, short-lived, and validated at the load balancer.

D NLB passthrough

No validation at all.

THE SIGNAL

Clients authenticate with certificates you issue, checked at the edge: Private CA and mutual TLS.

> Meridian Freight runs a third-party API gateway appliance on EC2 that terminates TLS for a public domain. It needs a publicly trusted certificate and its private key installed on the instance.
>
> The team wants AWS to manage issuance and renewal rather than buying certificates manually.

What should the solutions architect use?

A. A standard ACM public certificate associated with the instance

B. A certificate from AWS Private CA

C. A self-signed certificate rotated by a Lambda function

D. An ACM exportable public certificate, redeployed to the appliance when ACM renews it

◆ PAUSE AND DECIDE

What should the solutions architect use?

A Standard ACM certificate

Its private key cannot be exported, and it cannot attach to an instance.

B Private CA

Not trusted by public browsers or clients.

C Self-signed

Not publicly trusted.

D ACM exportable certificate

Public trust, private key available, renewed by ACM.

THE SIGNAL

Public trust, key on your own server, AWS-managed renewal: exportable public certificate.

> Meridian Freight encrypts sensitive fields client-side with KMS before writing to a DynamoDB global table in two Regions.
>
> During a full outage of the first Region, the application in the second Region must decrypt those fields without calling the first Region.

What should the solutions architect use?

A. A multi-Region customer managed key, with a replica in the second Region

B. Separate keys per Region, with each item encrypted under both

C. The DynamoDB table's default encryption with an AWS owned key

D. One single-Region key, called cross-Region from the second Region

◆ PAUSE AND DECIDE

What should the solutions architect use?

A Multi-Region key

The replica decrypts locally, because it shares key material.

B Encrypt under both keys

Works, but doubles the encryption and the complexity.

C Table default encryption

Protects at rest, not the client-side field encryption required.

D Cross-Region call

Fails exactly when the first Region is down.

THE SIGNAL

Ciphertext replicated as-is, decrypted elsewhere when the source Region is gone: multi-Region keys.

What to carry out of this module

- **Customer managed keys** for control, cross-account use and custom rotation.
- **Rotation** 90 to 2560 days, same key ID, KMS-generated symmetric keys only.
- **Single tenant:** CloudHSM key store. **Outside AWS:** external key store.
- **ACM** public and exportable; **Private CA** for internal and client identity.
- **Multi-Region keys** when ciphertext crosses Regions and must decrypt there.

> ON THE EXAM
>
> Ask who controls the key, where the material lives, and how it rotates.